XAVAULT V1

Robustness, security and launch-readiness priorities

Purpose

This document turns the current XAVAULT review into an execution order for V1. Critical and High items are launch gates. Medium items should be scheduled into the first stability cycle. Low items improve polish after the financial and security foundations are proven.

PRIORITY	RELEASE MEANING
Critical	Do not launch publicly until resolved and tested.
High	Required for a dependable, supportable V1.
Medium	Complete before scale or shortly after controlled launch.
Low	Post-launch quality and optimization work.

CRITICAL

Must be completed before a public financial launch.

CRITICAL

Production HTTPS configuration

Replace the hardcoded private HTTP API address with environment-based development, staging, and production HTTPS URLs. Validate required configuration during application startup.

CRITICAL

Financial reconciliation

Run scheduled checks comparing wallet balances, locked balances, ledger totals, deposits, and withdrawals. Alert and stop unsafe processing when invariants fail.

CRITICAL

Webhook idempotency and recovery

Persist Paystack event identifiers, reject duplicate processing, retry transient failures safely, and reconcile transfers or deposits stuck in pending/processing states.

CRITICAL

Database recovery

Use automated encrypted backups and perform a tested restore exercise before launch. Define recovery time and recovery point targets.

HIGH

Security and reliability controls required for a dependable V1.

HIGH

Authentication rate limiting

Rate-limit login, registration verification, password reset, biometric challenges, withdrawal PIN verification, and OTP resend endpoints by account, IP, and device.

HIGH

Versioned database migrations

Replace production reliance on AutoMigrate with reviewed, reversible, versioned migrations and deployment checks.

HIGH

End-to-end money-flow tests

Cover deposit, duplicate webhook, plan allocation, withdrawal, incorrect PIN lockout, provider timeout, transfer reversal, logout, and session refresh.

HIGH

Secret and token hardening

Fail startup when JWT or provider secrets are missing or weak. Add key rotation procedures, session/device management, and logout-all-devices support.

HIGH

Operational alerting

Alert on failed webhooks, amount mismatches, duplicate references, negative balances, long-running transfers, repeated authentication failures, and reconciliation differences.

MEDIUM

Improves supportability, clarity, and day-to-day resilience.

MEDIUM

Structured observability

Use structured logs with request IDs, user-safe correlation IDs, latency metrics, and centralized error monitoring. Never log complete payment payloads or secrets.

MEDIUM

Consistent error experience

Extend the existing ErrorModal pattern to deposits, subscriptions, authentication, and profile changes. Give financial failures a support reference ID.

MEDIUM

Network and offline handling

Add explicit offline, timeout, retry, and uncertain-payment states. Never represent a timed-out financial request as definitively failed without verification.

MEDIUM

Administrative reconciliation tools

Provide protected tools to inspect a reference, compare provider and local state, replay safe processing, and record operator actions.

MEDIUM

CORS and platform validation

Permit the methods actually used by browser clients, including PUT, and test Android, iOS, and Expo Web behavior independently.

LOW

Quality improvements that can follow the launch-critical work.

LOW

Performance polish

Profile large transaction histories, introduce cursor pagination where appropriate, and optimize images, startup requests, and query cache behavior.

LOW

Accessibility review

Verify screen-reader labels, focus order, dynamic text sizing, contrast, touch targets, and reduced-motion behavior.

LOW

Product analytics

Measure onboarding completion, failed deposit/withdrawal steps, subscription conversion, and recovery flow completion without collecting sensitive financial data.

LOW	**Support content** Add concise explanations for pending transactions, PIN lockout, reversals, subscription activation, and expected processing times.

Completed hardening work

DONE	Logout revokes the stored refresh token and expires authentication cookies.
DONE	Deposit lookup and verification enforce authenticated ownership.
DONE	Subscription activation validates user, plan, reference, amount, currency, and pending status.
DONE	Bearer tokens take precedence over stale authentication cookies.
DONE	Paystack subscription response parsing no longer uses unsafe type assertions.
DONE	Two incorrect withdrawal PIN attempts lock withdrawals until PIN reset.
DONE	Withdrawal failures and rejected previews use the app ErrorModal.
DONE	The Me/Profile tab links to the combined Transactions screen.
DONE	Go tests, TypeScript checking, and mobile lint pass.

Recommended next sprint

1. Production HTTPS and environment validation.
2. Webhook idempotency plus pending-payment reconciliation.
3. Authentication and OTP rate limiting.
4. Versioned migrations and backup restoration test.
5. End-to-end tests for deposits, withdrawals, lockout, reversal, and logout.

Exit condition: public launch should require all Critical work complete, all High risks either complete or explicitly accepted, a successful restore exercise, and a clean end-to-end financial-flow test run.